

MORPETH SCHOOL WEBSITE STAFF AREA GOOGLE LOGIN IT HANDOVER DOCUMENT

Document purpose

This document explains exactly what IT must configure so the new website staff area can only be accessed by approved Morpeth staff Google accounts.

Important domain context (confirmed)

Current new-site production host in Vercel:

- <https://morpeth-site.vercel.app>

Future public domain after cutover:

- <https://www.morpethschool.org.uk>

Current situation:

- The old website is still on <https://www.morpethschool.org.uk>
- Until DNS/cutover is switched, OAuth callback must use the Vercel host (not the final domain).

Do not use the deployment-specific URL as callback:

- <https://morpeth-site-8xouluxh5-morpeth-schools-projects.vercel.app>

Reason: deployment URLs can change and are not stable.

System summary

The staff area (/staff) is protected by Google sign-in.

Unauthenticated users are redirected to /staff/login.

After successful sign-in, the site verifies the account domain and creates a secure session cookie.

Only users in approved domain(s) are allowed into the staff area.

Affected website paths

Protected page(s):

- /staff (and child staff paths)

Authentication UI:

- /staff/login

Auth endpoints:

- /api/staff-auth/login
- /api/staff-auth/callback
- /api/staff-auth/logout

Required configuration values (Vercel environment variables)

Set all of the following variables in Vercel Project Settings -> Environment Variables.

1) STAFF_GOOGLE_CLIENT_ID

Google OAuth client ID.

2) STAFF_GOOGLE_CLIENT_SECRET

Google OAuth client secret.

3) STAFF_GOOGLE_REDIRECT_URI

Exact callback URL registered in Google Cloud OAuth settings.

Set this now (before cutover):

- <https://morpeth-site.vercel.app/api/staff-auth/callback>

Set this after domain cutover:

- <https://www.morpethschool.org.uk/api/staff-auth/callback>

Important: this must be an exact match to one authorized redirect URI in Google Cloud.

4) STAFF_ALLOWED_GOOGLE_DOMAINS

Comma-separated list of allowed Google Workspace domains.

Example:

morpeth.school,morpeth.towerhamlets.sch.uk

Only accounts from these domains can access /staff.

5) STAFF_AUTH_SECRET

Long random secret used to sign/verify staff session cookies.

Recommendation: minimum 32 random bytes.

Use a password manager or secret generator.

Google Cloud setup procedure

Use a school-owned Google Cloud project.

Step 1

Open Google Cloud Console and select the correct project.

Step 2

Go to APIs & Services -> OAuth consent screen.

Configure app name and support email.

If policy allows, use Internal app type for Workspace users.

Step 3

Go to APIs & Services -> Credentials.

Create or edit an OAuth 2.0 Client ID (Web application).

Step 4

Add authorized redirect URIs (both):

- <https://morpeth-site.vercel.app/api/staff-auth/callback>
- <https://www.morpethschool.org.uk/api/staff-auth/callback>

Why both:

- First URL supports testing before DNS cutover.
- Second URL supports live operation after cutover.

Step 5

Copy Client ID and Client Secret into Vercel environment variables.

Vercel deployment steps

- 1) Add all required env vars to Production.
- 2) Redeploy after saving env vars.
- 3) Test login flow on current host.

Post-deployment validation checklist (before cutover)

1) Access <https://morpeth-site.vercel.app/staff> while signed out.
Expected: redirect to /staff/login.

2) Click Continue with Google and sign in with valid staff account.
Expected: redirect back to /staff and content loads.

3) Click Sign out.
Expected: session ends and /staff requires login again.

4) Negative test with non-staff account.
Expected: denied and returned to /staff/login.

Cutover day checklist

- 1) Switch domain to new site.
- 2) Update STAFF_GOOGLE_REDIRECT_URI to:

- <https://www.morpethschool.org.uk/api/staff-auth/callback>
- 3) Redeploy.
 - 4) Re-run validation on <https://www.morpethschool.org.uk/staff>

Security controls in place

- Server-side enforcement in middleware for /staff paths.
- Signed, expiring, httpOnly session cookie.
- Domain-based allowlist enforcement.
- OAuth state validation on callback to reduce CSRF risk.

Operational notes

Add/remove domains:

- Update STAFF_ALLOWED_GOOGLE_DOMAINS in Vercel, then redeploy.

Rotate session signing secret:

- Update STAFF_AUTH_SECRET in Vercel, redeploy.
- Existing sessions become invalid and users will sign in again.

If login fails for all users

Check in this order:

- 1) Redirect URI exact match between Google Cloud and STAFF_GOOGLE_REDIRECT_URI.
- 2) Correct Client ID and Client Secret values.
- 3) Correct STAFF_ALLOWED_GOOGLE_DOMAINS entries.
- 4) Deployment completed after env var changes.
- 5) Correct host in use (Vercel host before cutover, final domain after cutover).

Support handoff notes

Website code is already implemented and deployed.

IT action required is configuration only:

- Google Cloud OAuth settings
- Vercel env vars
- validation testing

End of document.